

UNIDAD 1

Introducción a la Seguridad de la Información





UNIDAD 1

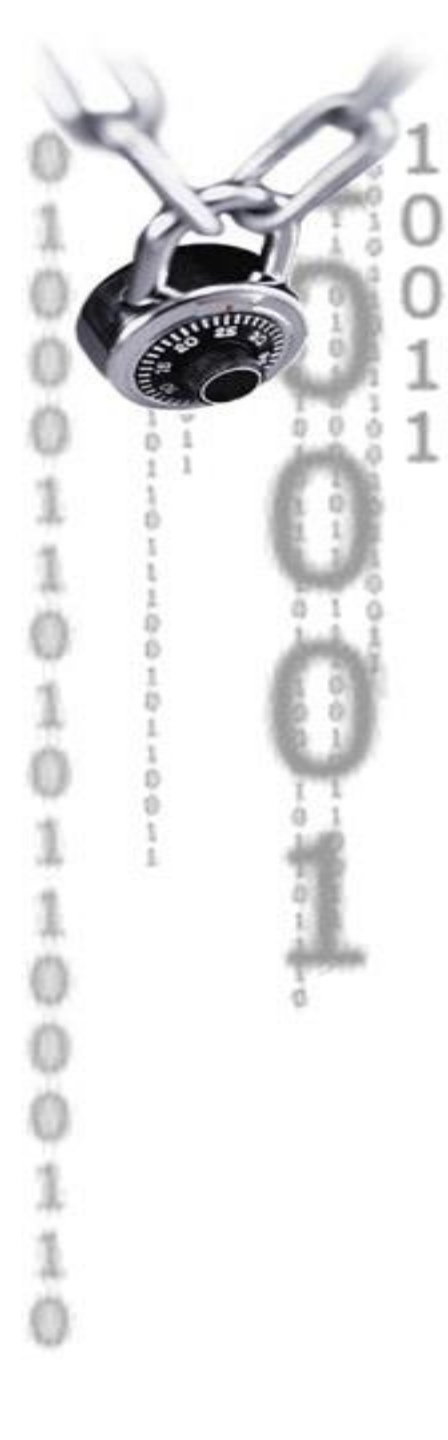
Objetivo

Que los alumnos logren:

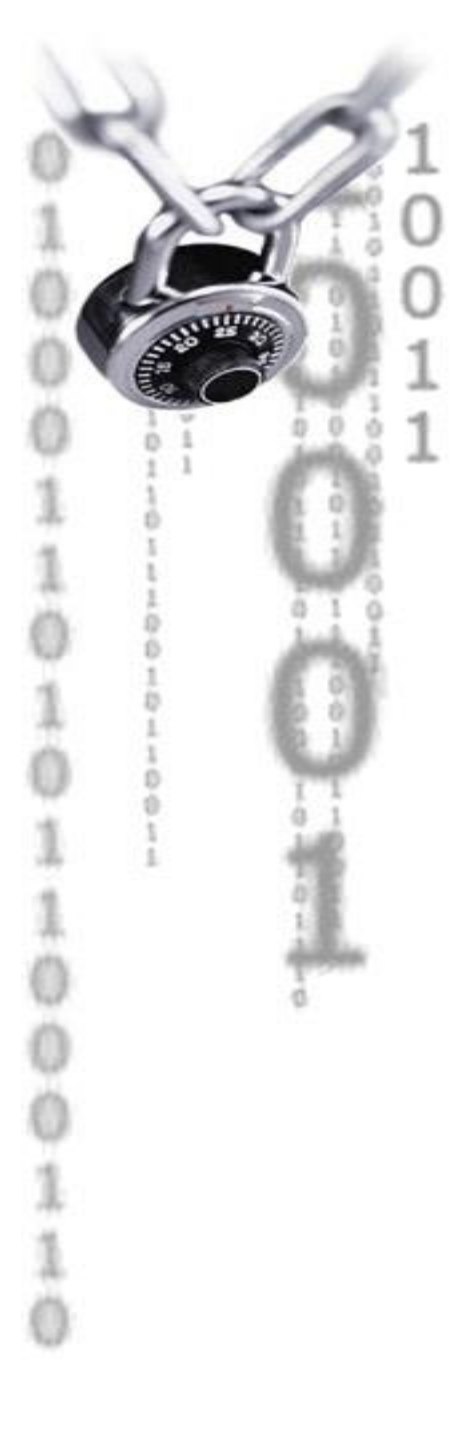
- Conocer el concepto de Sistema de gestión de seguridad de la información (SGSI)
- Definir etapas para el desarrollo y posterior mantenimiento de un SGSI.
- .

Contenido

- Sistema de Gestión de seguridad de la información.
- Etapas para el desarrollo e implementación de un sistema de gestión de seguridad de la información.



→ Un Sistema de Gestión de Seguridad de Información (SGSI) es un sistema gerencial general basado en un enfoque de riesgos para establecer, implementar, operar, monitorear, revisar, mantener y mejorar la seguridad de la información



SGSI es concepto central de ISO 27001

Sistema de gestión que comprende la política, la estructura organizativa, los procedimientos, los procesos y los recursos necesarios para implantar la gestión de la seguridad de la información.



- Es esencial que una organización identifique sus **requerimientos de seguridad**.
- Existen tres fuentes principales de **requerimientos de seguridad**:
 - Una fuente se deriva de evaluar los riesgos para la organización, tomando en cuenta la estrategia general y los objetivos de la organización. A través de la evaluación del riesgo, se identifican las amenazas para los activos, se evalúa la vulnerabilidad y la probabilidad de ocurrencia y se calcula el impacto potencial.
 - Otra fuente son los requerimientos legales, reguladores, estatutarios y contractuales que tienen que satisfacer una organización, sus socios comerciales, contratistas y proveedores de servicio; y su ambiente socio-cultural.
 - Otra fuente es el conjunto particular de principios, objetivos y requerimientos comerciales para el procesamiento de la información que una organización ha desarrollado para sostener sus operaciones

PLANIFICAR (PLAN)

- Definir alcance
- Definir política de seguridad
- Método de evaluación de riesgos
- Inventario de activos
- Amenazas y vulnerabilidades
- Identificar impactos
- Análisis de evaluación de riesgos
- Selección de controles y SOA

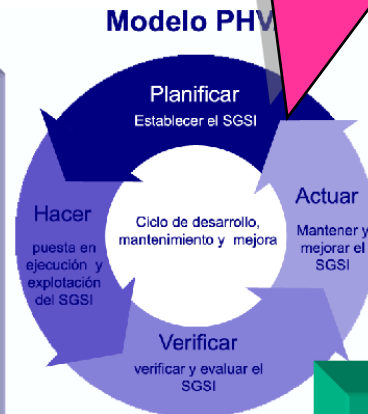
Arranque del proyecto

MEJORA CONTINUA (ACT)

- Implantar mejoras
- Acciones correctivas
- Acciones preventivas
- Comprobar eficiencia de las acciones

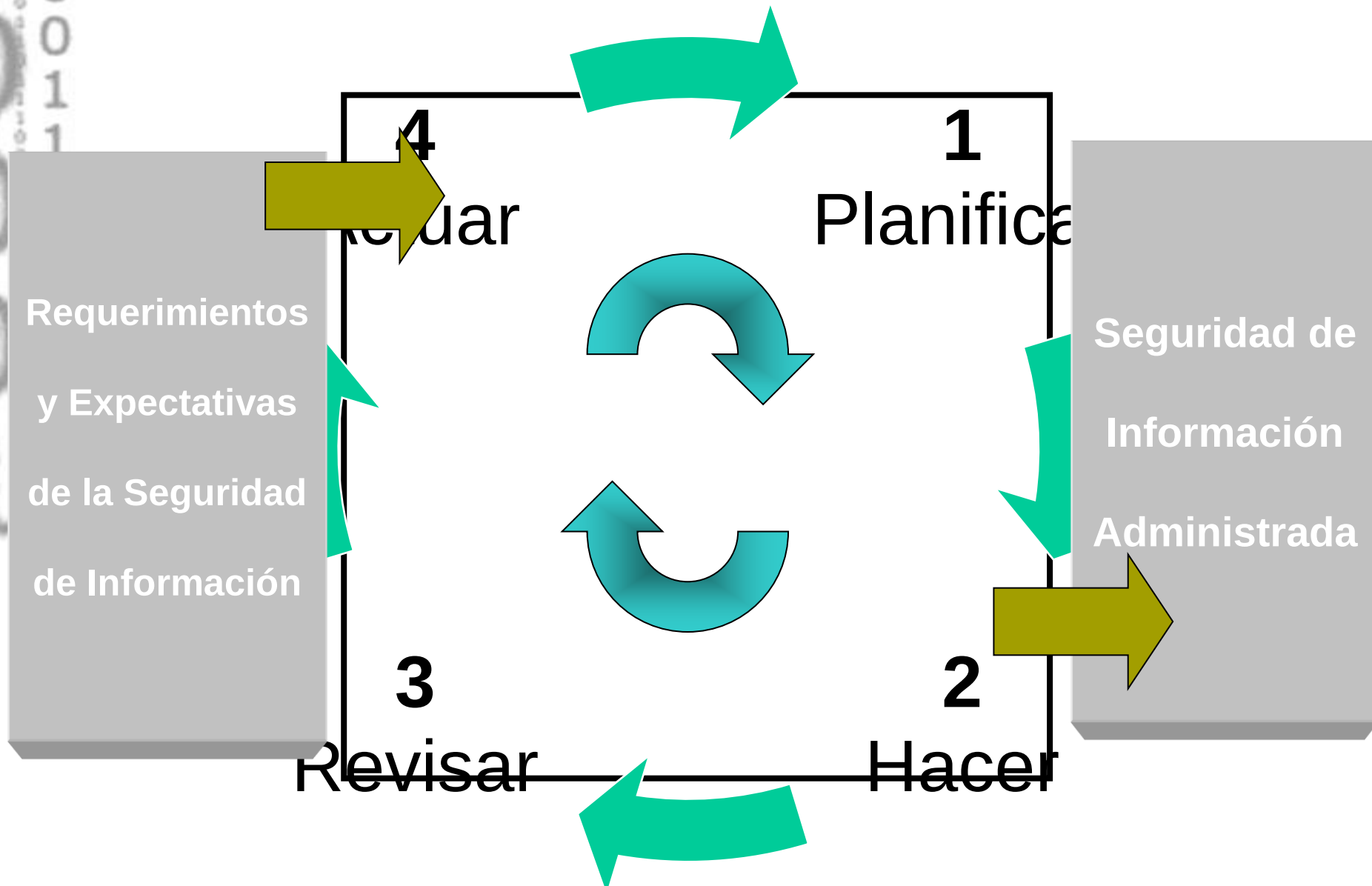
HACER (DO)

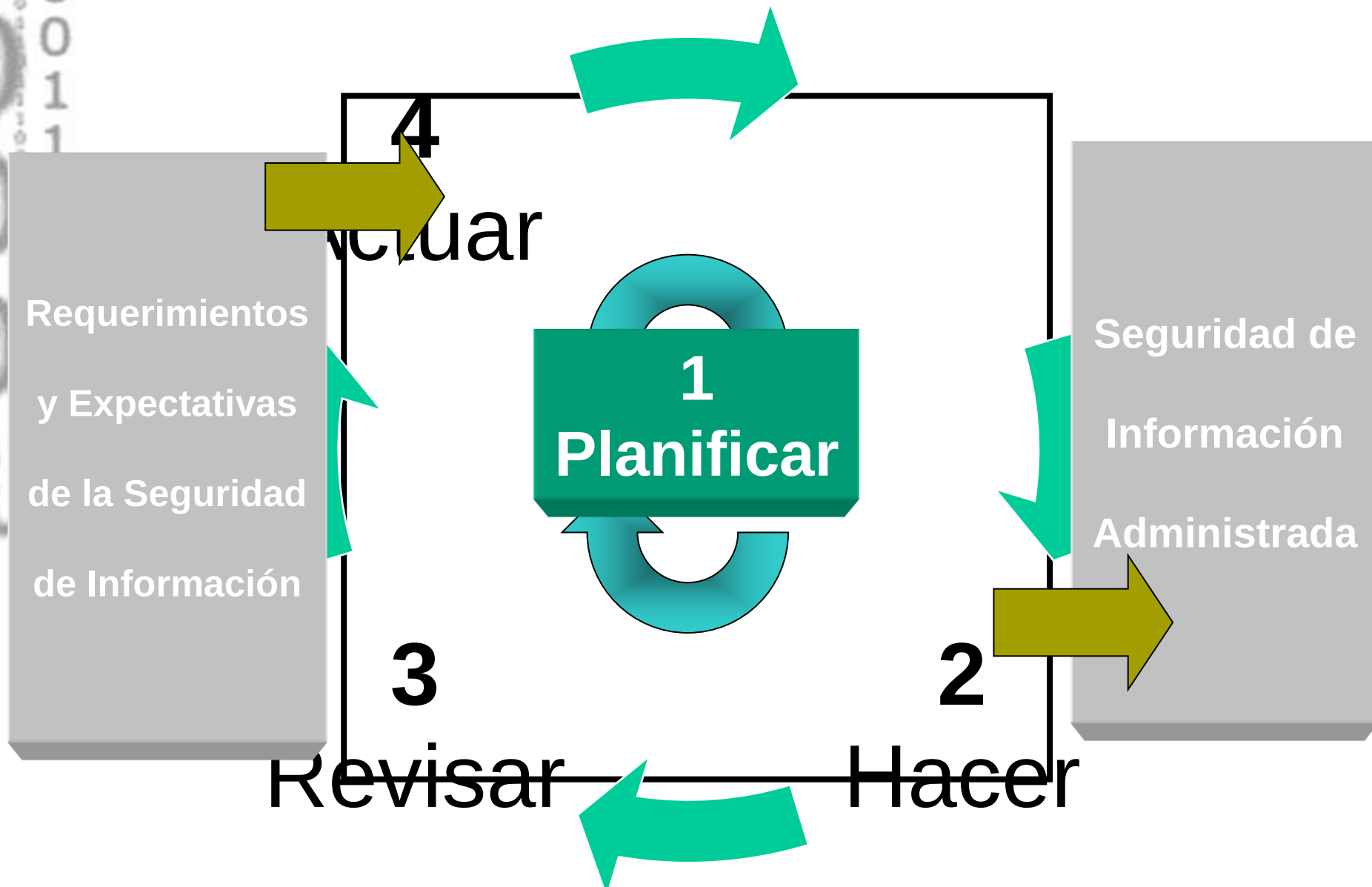
- Definir plan de tratamiento de riesgos
- Implantar plan de tratamiento de riesgos
- Implementar controles
- Formación y concientización
- Operar SGSI



VERIFICAR (CHECK)

- Revisar SGSI
- Medir eficiencia de los controles
- Revisar riesgos residuales
- Realizar auditorías internas
- Registrar acciones y eventos







- Planificar.
 - Definir el alcance en términos de las características del negocio, la organización, ubicación, activos, tecnología.
 - Definir una política del SGSI que incluya:
 - El sentido de la dirección general para la acción respecto a la Seguridad de la Información.
 - Requerimientos legales.
 - Alineación con la gestión estratégica de la organización.
 - El criterio de evaluación del riesgo.
 - Aprobación de la alta gerencia.



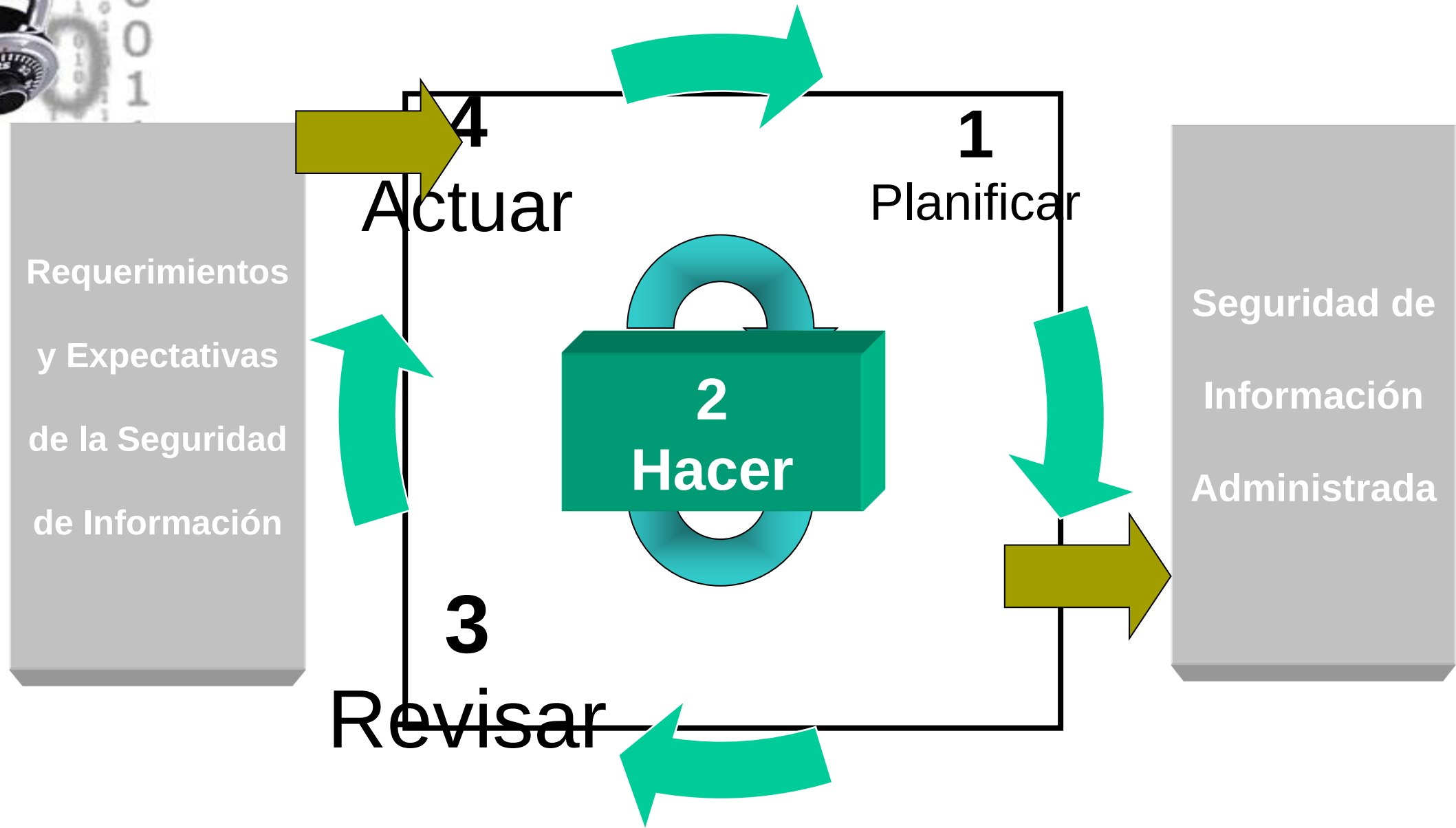
- Planificar.
 - Definir el enfoque de evaluación del riesgo de la organización.
 - Establecer metodología de cálculo del riesgo.
 - Establecer criterios de aceptación del riesgo y niveles de aceptación del mismo.
 - Identificar los riesgos asociados al alcance establecido.
 - Analizar y evaluar los riesgos encontrados.



- Planificar.
 - Identificar y evaluar las opciones de tratamiento de los riesgos.
 - Aplicar controles.
 - Aceptarlo de acuerdo a los criterios de aceptación.
 - Evitarlo.
 - Transferirlo.
 - Seleccionar objetivos de control y controles sugeridos por la norma y/u otros que apliquen.

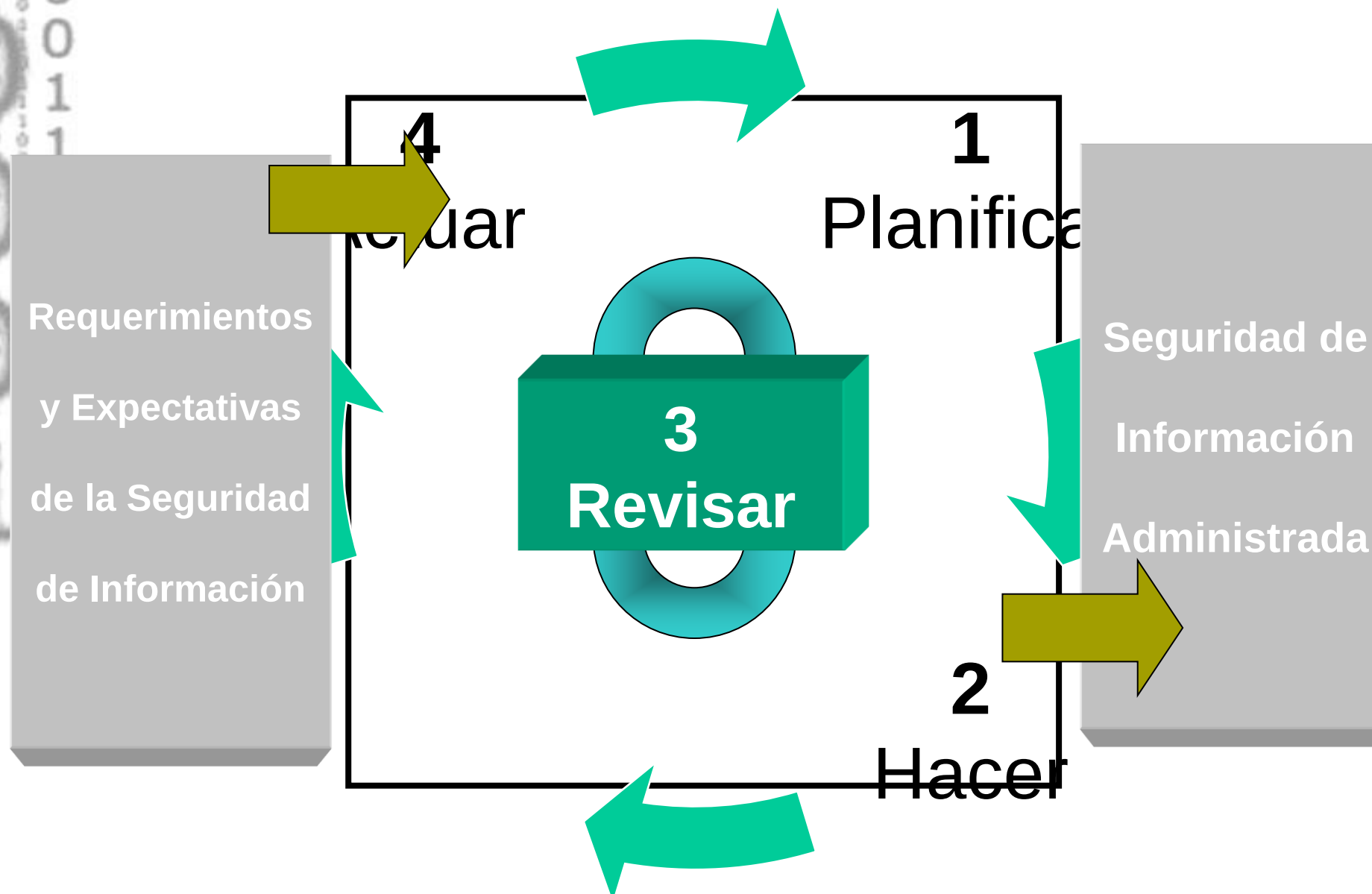


- Planificar.
 - Obtener la aprobación de la gerencia para los riesgos residuales e implementar el SGSI.
 - Preparar el Enunciado de Aplicabilidad.





- Hacer.
 - Plan de tratamiento del riesgo.
 - Implementar el plan de tratamiento del riesgo.
 - Implementar controles seleccionados.
 - Definir la medición de la efectividad de los controles a través de indicadores de gestión.
 - Implementar programas de capacitación.
 - Manejar las operaciones y recursos del SGSI.
 - Implementar procedimientos de detección y respuesta a incidentes de seguridad.

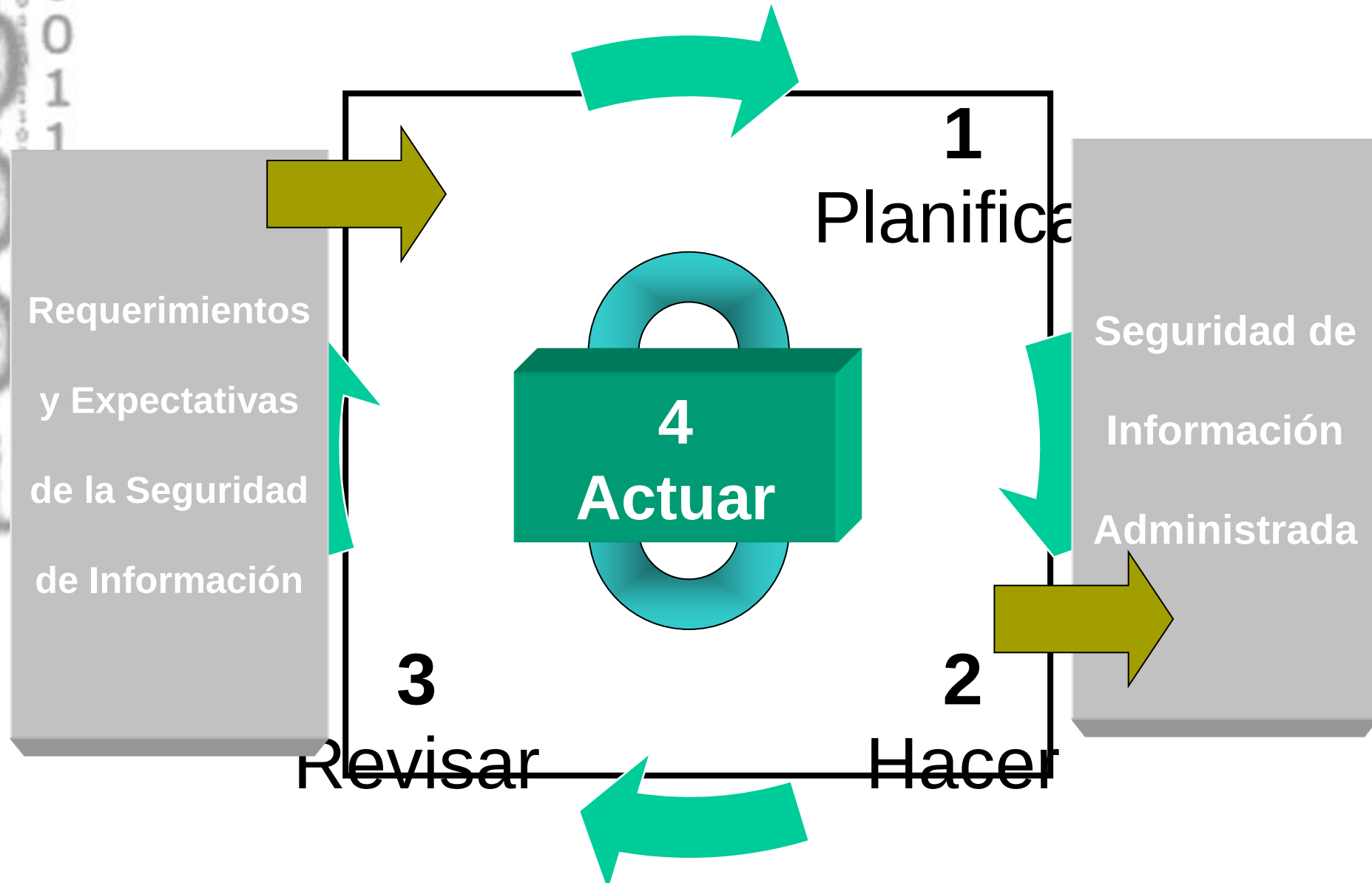




- Revisar.
 - Procedimientos de monitoreo y revisión para:
 - Detectar oportunamente los errores.
 - Identificar los incidentes y violaciones de seguridad.
 - Determinar la eficacia del SGSI.
 - Detectar eventos de seguridad antes que se conviertan en incidentes de seguridad.
 - Determinar efectividad de las acciones correctivas tomadas para resolver una violación de seguridad.
 - Realizar revisiones periódicas.



- Revisar.
 - Medición de la efectividad de los controles.
 - Revisar las evaluaciones del riesgo periódicamente y revisar el nivel de riesgo residual aceptable.
 - Realizar auditorías internas al SGSI.
 - Realizar revisiones gerenciales.
 - Actualizar los planes de seguridad a partir de resultados del monitoreo.
 - Registrar las acciones y eventos con impacto sobre el SGSI.





- Actuar.
 - Implementar las mejoras identificadas en el SGSI.
 - Aplicar acciones correctivas y preventivas de seguridad al SGSI.
 - Comunicar los resultados y acciones a las partes interesadas.
 - Asegurar que las mejoras logren sus objetivos señalados.